
Royaume du Maroc • Université Hassan II de Casablanca
École Nationale Supérieure d'Électricité et de Mécanique – ENSEM

Département : Génie Informatique
Filière : Génie Logiciel et Intelligence Artificielle

Logo
Université Hassan II

Logo
ENSEM

RAPPORT DE PROJET DE FIN D'ÉTUDES

Réalisé au sein de [Nom de la Société]

Logo Société

THÈME :

GRC AI Analyzer

Plateforme d'analyse automatisée des rapports
de gouvernance, risque et conformité
propulsée par l'Intelligence Artificielle Générative

Soutenu le ____ - ____ - 2026 **par :**

– Mahdi BOUKHOUALI

Encadré par :

– Prof. [Nom Prénom] (Encadrant
ENSEM)

– M. [Nom Prénom] (Encadrant In-
dustriel)

Devant les membres du jury :

– Pr. [Nom Prénom] Président

– Pr. [Nom Prénom] Rapporteur

– Pr. [Nom Prénom] Encadrant ENSEM

– M. [Nom Prénom] Encadrant Industriel

Promotion 2026

Dédicace

C'est avec une profonde gratitude et une immense fierté que je dédie ce modeste travail, fruit de plusieurs mois d'efforts et de recherche, aux personnes qui ont marqué mon parcours académique et personnel.

Je dédie ce rapport en premier lieu à ma famille, et plus particulièrement à mes chers parents, qui ont toujours été ma source d'inspiration et le pilier de ma réussite. Aucun mot ne saurait exprimer l'ampleur de ma reconnaissance pour leurs innombrables sacrifices, leur soutien inconditionnel et leurs prières qui m'ont accompagné dans chaque étape.

À mes frères et sœurs, pour leur présence réconfortante et leur belle complicité. Que ce travail soit l'humble témoignage de mon affection et de ma gratitude éternelle.

Je dédie également ce projet à mes encadrants, dont l'orientation rigoureuse, la disponibilité et les précieux conseils ont été une véritable boussole tout au long de ce stage de fin d'études.

Enfin, je souhaite dédier ce travail à tous mes amis, collègues et professeurs de l'école, qui ont contribué, de près ou de loin, à mon évolution et à l'aboutissement de ce projet.

Remerciements

Je tiens à exprimer ma plus sincère gratitude à l'ensemble des personnes qui ont contribué à la réalisation de ce travail, tant sur le plan académique que professionnel et personnel.

Tout d'abord, je remercie chaleureusement mes parents pour leur amour inconditionnel, leur patience inépuisable et leur soutien indéfectible tout au long de mon parcours. Leur confiance en moi et leurs encouragements constants ont été le pilier de ma réussite.

Je tiens également à exprimer toute ma reconnaissance à mon encadrant pédagogique, Prof. [Nom de l'encadrant académique], pour sa disponibilité, ses conseils judicieux et son accompagnement rigoureux. Son regard critique et ses orientations méthodologiques ont grandement contribué à la qualité de ce projet.

Mes remerciements vont également à mon encadrant professionnel, M. [Nom de l'encadrant industriel], pour sa confiance, son suivi attentif et son partage d'expertise dans le domaine de la gouvernance, du risque et de la conformité. Sa vision technique et métier a grandement enrichi ce travail.

Je remercie aussi l'ensemble de l'équipe avec laquelle j'ai eu le privilège de collaborer durant cette période. Les échanges enrichissants et l'esprit collaboratif ont fait de cette expérience une aventure humaine et professionnelle inoubliable.

Enfin, j'adresse mes remerciements à l'ensemble du corps professoral de l'ENSEM, ainsi qu'à mes camarades de promotion, pour les années de formation qui ont rendu possible ce projet.

Résumé

Dans un contexte mondial marqué par la multiplication des réglementations en matière de protection des données et de cybersécurité, les organisations sont confrontées à une charge croissante d'analyse de leurs rapports de gouvernance, de risque et de conformité (GRC). L'analyse manuelle de ces documents est chronophage, sujette aux erreurs et difficilement scalable.

C'est dans ce cadre que s'inscrit ce projet de fin d'études, dont l'objectif est la conception et la réalisation de **GRC AI Analyzer**, une plateforme *full-stack* d'analyse automatisée des rapports GRC propulsée par l'intelligence artificielle générative. Le système permet l'import de documents aux formats PDF, DOCX et XLSX, puis exploite le modèle **Mistral AI** pour extraire automatiquement les risques, évaluer la conformité vis-à-vis des référentiels **ISO 27001**, **RGPD** et de la **Loi 09-08** marocaine, et générer des recommandations concrètes.

L'architecture repose sur un backend **FastAPI** asynchrone, une persistance **PostgreSQL**, un stockage objet **MinIO**, une base vectorielle **ChromaDB** pour le *Retrieval Augmented Generation* (RAG), et une interface utilisateur **React/Vite** moderne. Un pipeline d'analyse en deux phases parallèles assure des temps de traitement réduits, tandis qu'une interface conversationnelle basée sur le RAG permet à l'utilisateur d'interroger directement le rapport analysé.

Mots-clés : GRC, Intelligence Artificielle, Mistral, RAG, ChromaDB, FastAPI, React, ISO 27001, RGPD, Loi 09-08, conformité, gestion des risques.

Abstract

In a global context marked by the multiplication of regulations regarding data protection and cybersecurity, organizations face a growing burden in analyzing their Governance, Risk and Compliance (GRC) reports. Manual analysis of these documents is time-consuming, error-prone and hardly scalable.

This end-of-studies project introduces **GRC AI Analyzer**, a full-stack platform for automated GRC report analysis powered by generative artificial intelligence. The system enables document upload in PDF, DOCX and XLSX formats, then leverages the **Mistral AI** model to automatically extract risks, evaluate compliance against **ISO 27001**, **GDPR** and Morocco's **Law 09-08**, and generate concrete recommendations.

The architecture relies on an asynchronous **FastAPI** backend, a **PostgreSQL** database, a **MinIO** object store, a **ChromaDB** vector database for Retrieval Augmented Generation (RAG), and a modern **React/Vite** user interface. A two-phase parallel analysis pipeline ensures reduced processing times, while a conversational interface based on RAG allows users to directly interrogate analyzed reports.

Keywords : GRC, Artificial Intelligence, Mistral, RAG, ChromaDB, FastAPI, React, ISO 27001, GDPR, Law 09-08, compliance, risk management.

Table des matières

Dédicace	I
Remerciements	II
Résumé	III
Abstract	IV
Liste des acronymes	VIII
1 Présentation du cadre du projet	1
1.1 Introduction	1
1.2 Présentation de l'organisme d'accueil	1
1.2.1 Présentation générale	1
1.2.2 Domaines d'expertise et offre de services	1
1.2.3 Positionnement et clientèle	2
1.2.4 Cadre du projet GRC AI Analyzer	2
1.3 Contexte métier : la Gouvernance, le Risque et la Conformité (GRC) . . .	3
1.3.1 Les trois piliers de la GRC	3
1.3.2 Cadres réglementaires et normatifs retenus	4
1.3.3 Enjeux de l'analyse documentaire GRC	6
1.4 Étude de l'existant	7
1.4.1 Pratiques actuelles d'analyse des rapports GRC	7
1.4.2 Limites des approches existantes	8
1.4.3 Solutions du marché et limites de l'existant	8
1.5 Problématique du projet	9
1.6 Solution envisagée	9
1.7 Objectifs du projet	10

1.8	Conduite du projet	11
1.9	Conclusion	11
2	Etude et Analyse de L'existant	12
2.1	Analyse des Besoins	12
2.1.1	Identification des acteurs	12
2.1.2	Besoins fonctionnels	12
2.1.3	Besoins non fonctionnels	15
2.2	Diagramme des Cas d'Utilisation	16
2.2.1	Description générale	16
2.2.2	Description des cas d'utilisation principaux	18
2.3	Diagramme de Classes	19
2.3.1	Vue d'ensemble	19
2.3.2	Description des classes principales	20
2.3.3	Relations entre classes	22
2.4	Diagramme de Séquence	23
2.4.1	Séquence principale : Analyse d'un rapport GRC	24
2.4.2	Description détaillée des interactions	24
2.5	Diagramme d'Activité	26
2.5.1	Vue d'ensemble du flux de traitement	26
2.5.2	Description des activités	28
3	Conception technique et choix technologiques	31
3.1	Introduction	31
3.2	Vision générale de la solution cible	31
3.2.1	Principes directeurs	31
3.3	Architecture en couches du backend	32
3.4	Pipeline d'analyse asynchrone en deux phases	32
3.5	Modèle RAG	32
3.6	Modèle de données (PostgreSQL)	33

3.7	Choix technologiques	33
3.8	Principes de sécurité retenus	33
3.9	Conclusion	34
4	Sprint 1 : Authentification et gestion des utilisateurs	36
4.1	Introduction	36
4.2	Objectifs et périmètre	36
4.3	Diagramme de séquence : connexion	36
4.4	Extrait de code : génération JWT	36
4.5	Résultats fonctionnels	37
4.5.1	Interface de connexion	37
4.5.2	Interface d'inscription	37
4.5.3	Politique de mot de passe	38
4.6	Difficultés rencontrées	38
4.7	Bilan du Sprint 1	38
5	Sprint 2 : Upload et parsing documentaire	39
5.1	Introduction	39
5.2	Objectifs	39
5.3	Architecture du module	39
5.4	Stratégies d'extraction par format	40
5.5	Chunking et préparation pour le RAG	40
5.6	Bilan du Sprint 2	40
6	Sprint 3 : Pipeline d'analyse IA	41
6.1	Introduction	41
6.2	Architecture du pipeline	41
6.3	Prompt engineering	42
6.4	Sérialisation des appels Mistral	42
6.5	Résultats	43
6.5.1	Matrice probabilité/impact des risques	43

6.5.2	Radar de conformité	43
6.6	Bilan du Sprint 3	43
7	Sprint 4 : RAG et chat conversationnel	44
7.1	Introduction	44
7.2	Indexation vectorielle	44
7.3	Pipeline de question-réponse	44
7.4	Tolérance aux pannes	45
7.5	Résultats	45
8	Sprint 5 : Dashboards, exports et supervision	46
8.1	Introduction	46
8.2	Tableau de bord utilisateur	46
8.3	Exports professionnels	46
8.4	Polling côté frontend	47
8.5	Tableau d'administration	47
	Conclusion générale	48
	Bibliographie	50

Table des figures

1.1	Les quatre pôles de l'offre Evolvity Partners	2
1.2	Limites identifiées dans les pratiques actuelles	8
1.3	Architecture simplifiée de la solution cible	10
1.4	Processus général de la méthode Agile Scrum appliquée au projet	11
2.1	Diagramme des cas d'utilisation — GRC AI Analyzer	17
2.2	Diagramme de classes — modèle du domaine GRC AI Analyzer	20
2.3	Diagramme de séquence — Analyse d'un rapport GRC	24
2.4	Diagramme d'activité — flux de traitement GRC AI Analyzer	27
3.1	Architecture globale de GRC AI Analyzer	31
3.2	Organisation en couches du backend FastAPI	32
3.3	Pipeline d'analyse en deux phases parallèles	33
3.4	Pipeline RAG : indexation et requêtage	33
3.5	Modèle relationnel simplifié	34
4.1	Diagramme de séquence – Connexion JWT	37
5.1	Pipeline d'ingestion documentaire	39
6.1	Pipeline d'analyse en deux phases parallèles	41
6.2	Matrice probabilité/impact – exemple de visualisation des risques	43

Liste des tableaux

1.1	Référentiels de conformité couverts par la plateforme	5
2.1	Relations entre les classes du domaine	23
3.1	Synthèse des choix techniques	35
4.1	Difficultés du Sprint 1 et solutions	38
5.1	Stratégies d'extraction par format documentaire	40

Liste des acronymes

API	Application Programming Interface
CRUD	Create, Read, Update, Delete
DTO	Data Transfer Object
GRC	Governance, Risk and Compliance
ISO	International Organization for Standardization
JWT	JSON Web Token
LLM	Large Language Model
ORM	Object Relational Mapping
PDF	Portable Document Format
PFE	Projet de Fin d'Études
RAG	Retrieval Augmented Generation
REST	Representational State Transfer
RGPD	Règlement Général sur la Protection des Données
SPA	Single Page Application
SQL	Structured Query Language
UI	User Interface
UX	User Experience

1. Présentation du cadre du projet

1.1 Introduction

Ce premier chapitre a pour objectif de placer le projet dans son environnement professionnel, métier et réglementaire. Avant d'aborder l'analyse détaillée des besoins et la conception de la solution, il est nécessaire de comprendre le contexte dans lequel s'inscrit la création de *GRC AI Analyzer*, une plateforme d'analyse automatisée des rapports de gouvernance, risque et conformité propulsée par l'intelligence artificielle.

Le chapitre présente d'abord l'organisme d'accueil, ainsi que le contexte métier de la GRC. Il expose ensuite les enjeux réglementaires (ISO 27001, RGPD, Loi 09-08), analyse les limites des approches manuelles existantes, formule la problématique du projet et présente la solution envisagée.

1.2 Présentation de l'organisme d'accueil

1.2.1 Présentation générale

Evolvity Partners est un cabinet marocain de conseil spécialisé en cybersécurité et en gestion des risques, fondé en 2022. S'appuyant sur un pool d'experts capitalisant plus de douze années d'expérience cumulée, la structure a connu une croissance rapide : deux consultants à sa création, quatre en 2024, dix en 2025, avec une projection d'expansion internationale à l'horizon 2027. Ses locaux accueillent aujourd'hui une équipe pluridisciplinaire dédiée à accompagner ses clients au Maroc et à l'international, selon une approche sur mesure conforme aux standards internationaux les plus exigeants.

1.2.2 Domaines d'expertise et offre de services

L'offre d'Evolvity Partners est structurée autour de quatre pôles complémentaires couvrant l'ensemble du spectre de la cybersécurité.

- **Audit** : Le pôle Audit déploie des missions d'évaluation à plusieurs niveaux : Organisationnel, Technique et Physique.
- **GRC** : Le pôle GRC constitue le cœur stratégique de l'activité et couvre :
- **Technologie** : Le pôle Technologie couvre les domaines émergents : Cloud, Block-

chain, IoT et OT, avec une capacité d'intégration de solutions sécurisées dans des environnements complexes et hétérogènes.

- **ISS As A Service** : Ce modèle de prestation externalisée met à disposition des clients des profils spécialisés en mode régie ou forfait : RSSI (*Responsable de la Sécurité des Systèmes d'Information*), SecOps, PMO et experts métier, offrant ainsi une flexibilité adaptée aux organisations ne disposant pas de ces compétences en interne.

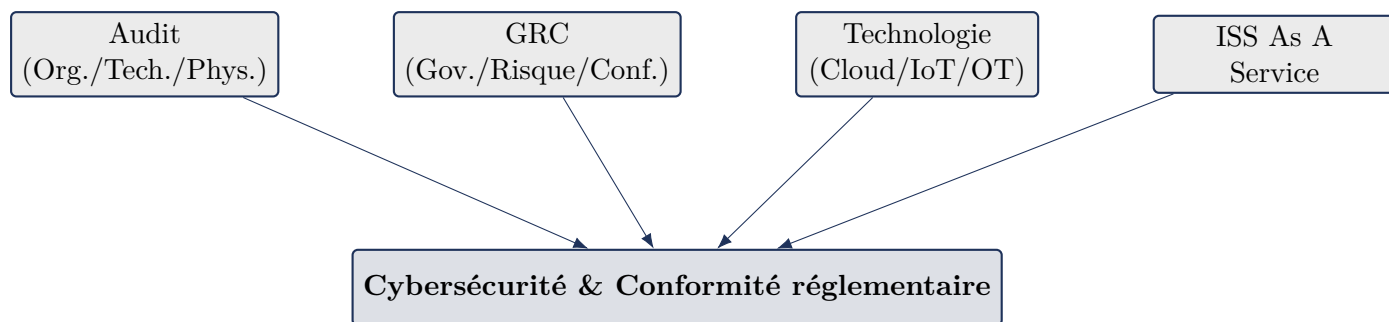


FIGURE 1.1 – Les quatre pôles de l'offre Evolvity Partners

1.2.3 Positionnement et clientèle

Evolvity Partners s'adresse principalement aux banques, institutions financières, administrations publiques et grandes entreprises opérant dans des secteurs réglementés. Son positionnement repose sur une approche qui allie rigueur technique, conformité réglementaire et gestion des risques stratégiques, avec pour objectif de protéger les actifs numériques de ses clients tout en accompagnant leur transformation digitale.

1.2.4 Cadre du projet GRC AI Analyzer

Le projet *GRC AI Analyzer*, objet du présent rapport, s'inscrit directement dans le pôle GRC d'Evolvity Partners. Face au volume croissant de rapports d'audit, de politiques de sécurité et de documents de conformité traités par les consultants, l'entreprise a identifié un besoin stratégique d'automatisation de l'analyse documentaire. Le projet vise à industrialiser cette pratique grâce à une plateforme propulsée par l'intelligence artificielle générative, réduisant ainsi les délais d'analyse et augmentant la précision des diagnostics de conformité. “

1.3 Contexte métier : la Gouvernance, le Risque et la Conformité (GRC)

La GRC (*Governance, Risk and Compliance*) désigne le cadre intégré par lequel une organisation structure et coordonne ses pratiques de gouvernance, de gestion des risques et de conformité réglementaire. Loin d'être trois disciplines indépendantes, ces trois dimensions forment un système cohérent : une gouvernance solide oriente la gestion des risques, qui elle-même conditionne la capacité de l'organisation à satisfaire ses obligations de conformité. Dans un contexte où les cybermenaces se multiplient et où les exigences réglementaires s'intensifient, la GRC est devenue un levier stratégique indispensable pour toute organisation souhaitant maîtriser son exposition et préserver la confiance de ses parties prenantes.

1.3.1 Les trois piliers de la GRC

Gouvernance

La gouvernance désigne l'ensemble des mécanismes par lesquels une organisation définit ses orientations stratégiques, répartit les responsabilités et s'assure que ses décisions sont alignées avec ses objectifs. En matière de sécurité de l'information, la gouvernance se traduit concrètement par :

- l'élaboration de politiques de sécurité et de chartes d'utilisation des systèmes d'information ;
- la définition de structures organisationnelles claires (RSSI, DPO, comités de sécurité) ;
- la mise en place d'indicateurs de pilotage (KPI, tableaux de bord) permettant un suivi continu de la maturité sécurité ;
- la conduite de programmes de sensibilisation et de formation des collaborateurs.

Une gouvernance efficace constitue le socle sur lequel reposent les deux autres piliers : sans cadre décisionnel clair, ni la gestion des risques ni la conformité ne peuvent être menées de manière cohérente.

Gestion des risques

La gestion des risques vise à identifier, analyser, évaluer et traiter les menaces susceptibles d'affecter les actifs stratégiques d'une organisation. Elle s'articule autour d'un processus itératif :

1. **Identification** : recensement des actifs (données, systèmes, processus) et des menaces associées ;
2. **Analyse** : évaluation de la probabilité et de l'impact de chaque scénario de risque ;
3. **Évaluation** : priorisation des risques selon leur niveau de criticité ;
4. **Traitement** : choix d'une stratégie parmi l'acceptation, la réduction, le transfert ou l'évitement du risque ;
5. **Suivi** : surveillance continue et réévaluation périodique.

Les méthodologies de référence utilisées dans ce domaine incluent notamment ISO 31000 (management du risque), ISO 27005 (gestion des risques liés à la sécurité de l'information) et EBIOS Risk Manager (méthode française d'analyse des risques numériques).

Conformité

La conformité désigne le respect des obligations légales, réglementaires, normatives et contractuelles applicables à l'organisation. Elle implique :

- une veille réglementaire permanente pour identifier les textes applicables ;
- des audits internes et externes réguliers pour mesurer l'écart entre l'état réel et les exigences ;
- la mise en œuvre de plans d'actions correctives pour résorber les non-conformités ;
- la production de rapports et de preuves documentaires à destination des autorités de contrôle.

La non-conformité expose l'organisation à des sanctions financières, des atteintes à sa réputation, voire des interruptions d'activité. C'est pourquoi la conformité ne saurait être traitée comme une contrainte ponctuelle, mais comme un processus continu intégré à la stratégie de l'entreprise.

1.3.2 Cadres réglementaires et normatifs retenus

Dans le cadre du projet GRC AI Analyzer, trois référentiels ont été sélectionnés pour leur pertinence stratégique dans le contexte marocain et international, ainsi que pour leur complémentarité dans la couverture des enjeux de sécurité et de protection des données.

Référentiel	Domaine	Portée
ISO 27001 :2022	Sécurité de l'information	Internationale
RGPD	Protection des données personnelles	Union Européenne
Loi 09-08	Protection des données personnelles	Royaume du Maroc

TABLE 1.1 – Référentiels de conformité couverts par la plateforme

ISO 27001 :2022 — Système de Management de la Sécurité de l'Information

La norme ISO/IEC 27001 est la référence internationale pour la mise en place, l'exploitation, la surveillance, la maintenance et l'amélioration continue d'un Système de Management de la Sécurité de l'Information (SMSI). Dans sa version 2022, elle s'articule autour de deux composantes principales :

- **Le corps normatif (clauses 4 à 10) :** il définit les exigences organisationnelles que tout SMSI doit satisfaire : contexte de l'organisation, leadership, planification, support, opérations, évaluation des performances et amélioration ;
- **L'annexe A :** elle regroupe 93 mesures de sécurité (contrôles) réparties en quatre catégories : organisationnelles (37), humaines (8), physiques (14) et technologiques (34).

L'obtention de la certification ISO 27001 atteste qu'une organisation a mis en place un SMSI conforme aux meilleures pratiques internationales. Elle est aujourd'hui exigée par de nombreux donneurs d'ordre, notamment dans les secteurs bancaire, assurantiel et des opérateurs d'importance vitale. L'analyse automatisée des écarts (*gap analysis*) par rapport aux exigences ISO 27001 constitue l'un des cas d'usage centraux de la plateforme GRC AI Analyzer.

RGPD — Règlement Général sur la Protection des Données

Entré en vigueur le 25 mai 2018, le Règlement (UE) 2016/679, dit RGPD, est le texte fondateur de la protection des données personnelles au sein de l'Union Européenne. Son champ d'application est extraterritorial : toute organisation, où qu'elle soit établie, qui traite des données de résidents européens est soumise à ses dispositions. Parmi ses principes structurants :

- **Licéité, loyauté et transparence :** le traitement doit reposer sur une base légale explicite (consentement, exécution d'un contrat, obligation légale, etc.) ;
- **Limitation des finalités :** les données collectées ne peuvent être utilisées qu'à des fins déterminées et légitimes ;

- **Minimisation des données** : seules les données strictement nécessaires doivent être collectées ;
- **Droits des personnes concernées** : droit d'accès, de rectification, d'effacement, de portabilité et d'opposition ;
- **Responsabilité (*accountability*)** : l'organisation doit être en mesure de démontrer sa conformité à tout moment.

Les sanctions prévues peuvent atteindre 20 millions d'euros ou 4 % du chiffre d'affaires mondial annuel. Le DPO (*Data Protection Officer*) joue un rôle central dans la supervision de la conformité RGPD au sein des organisations concernées.

Loi 09-08 — Protection des Données Personnelles au Maroc

Promulguée en 2009 et renforcée par la Loi 31-13 relative au droit d'accès à l'information, la Loi 09-08 constitue le cadre légal marocain de protection des données à caractère personnel. Elle est placée sous la supervision de la **CNDP** (Commission Nationale de contrôle de la protection des Données à caractère Personnel). Ses principales dispositions portent sur :

- l'obligation de déclaration ou d'autorisation préalable de tout traitement de données personnelles auprès de la CNDP ;
- le respect des droits des personnes concernées : droit d'information, d'accès, de rectification et d'opposition ;
- l'encadrement des transferts de données vers des pays tiers ;
- des obligations de sécurité et de confidentialité imposées aux responsables de traitement.

Si la Loi 09-08 présente des similitudes structurelles avec le RGPD européen, elle s'en distingue notamment par ses modalités de contrôle et l'étendue des obligations déclaratives. Dans le contexte des clients marocains d'Evolvity Partners, la double conformité RGPD / Loi 09-08 est fréquemment requise, justifiant l'intégration simultanée des deux référentiels dans la plateforme.

1.3.3 Enjeux de l'analyse documentaire GRC

Les cabinets de conseil en GRC produisent et analysent quotidiennement un volume considérable de documents : politiques de sécurité, rapports d'audit, plans de traitement des risques, preuves de conformité. L'analyse manuelle de ces documents est chronophage, sujette aux erreurs d'interprétation et difficile à standardiser entre consultants.

C'est précisément ce verrou opérationnel que le projet GRC AI Analyzer vise à lever, en automatisant l'extraction, la structuration et l'évaluation des informations pertinentes contenues dans ces documents, au regard des exigences des référentiels ISO 27001, RGPD et Loi 09-08.

1.4 Étude de l'existant

1.4.1 Pratiques actuelles d'analyse des rapports GRC

L'analyse des rapports de gouvernance, risque et conformité est aujourd'hui entièrement manuelle au sein des cabinets de conseil. Ce processus mobilise un consultant senior pendant plusieurs jours et se décompose en six étapes séquentielles, illustrées dans la figure ??.

1. **Réception du rapport** : le document est transmis au cabinet sous forme de fichier PDF, Word ou scan. Il peut s'agir d'une politique de sécurité, d'un rapport d'audit interne, d'un registre de traitements ou de tout autre livrable GRC.
2. **Lecture intégrale par un consultant senior** : un expert parcourt l'intégralité du document afin d'en saisir le contexte, d'identifier les sections pertinentes et de former un premier jugement sur la maturité de l'organisation.
3. **Surlignage manuel des passages à risque** : le consultant annote manuellement les passages susceptibles de révéler une non-conformité, une lacune de contrôle ou un risque non traité, sans garantie d'exhaustivité ni de cohérence inter-consultants.
4. **Saisie dans un tableur Excel ou Word** : les observations relevées sont retranscrites manuellement dans un modèle de rapport structuré, opération fastidieuse et source d'erreurs de saisie.
5. **Recoupement manuel avec les contrôles ISO / RGPD / 09-08** : chaque observation est mise en correspondance avec les exigences des référentiels applicables, nécessitant une connaissance approfondie et à jour de l'ensemble des contrôles concernés.
6. **Rédaction du rapport de synthèse** : le consultant produit un rapport final consolidé, incluant les écarts identifiés, leur niveau de criticité et les recommandations associées.

Ce processus présente plusieurs limites opérationnelles majeure. C'est l'ensemble de ces frictions que le projet GRC AI Analyzer vise à résoudre.

1.4.2 Limites des approches existantes

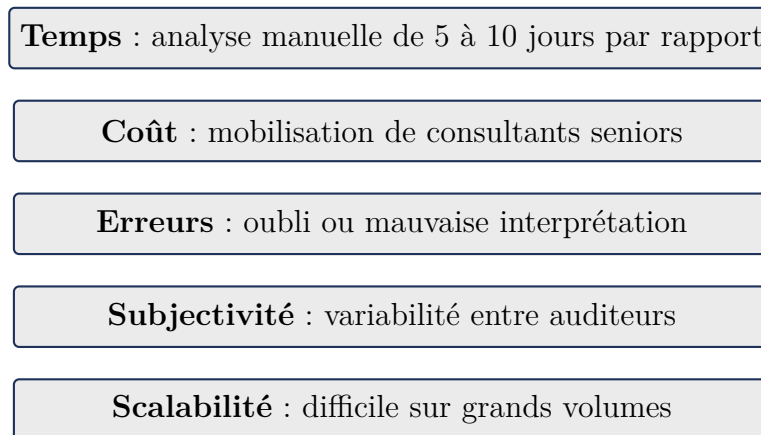


FIGURE 1.2 – Limites identifiées dans les pratiques actuelles

1.4.3 Solutions du marché et limites de l'existant

Leaders du marché GRC

Les plateformes commerciales dominantes — RSA Archer, ServiceNow GRC et MetricStream — offrent des fonctionnalités étendues de gestion des risques, des audits et de la conformité. Destinées aux grandes entreprises, elles souffrent néanmoins de limitations communes : coûts de licence prohibitifs, déploiements longs et complexes, et surtout une architecture basée sur la saisie manuelle de données structurées. Aucune ne propose d'analyse automatique de documents non structurés, et aucune ne couvre nativement le cadre réglementaire marocain (Loi 09-08).

Solutions open-source

Des outils tels qu'Eramba, SimpleRisk ou OpenGRC proposent des alternatives accessibles pour les organisations à budget limité. Ils couvrent les fonctions de base : registre des risques, suivi des contrôles, gestion des audits. Leurs limites sont toutefois significatives : interfaces rudimentaires, absence de support des référentiels régionaux, communautés restreintes, et aucune capacité d'analyse sémantique ou d'intelligence artificielle intégrée.

Outils basés sur les LLM

L'intégration des modèles de langage dans le domaine GRC est embryonnaire. Quelques expérimentations existent : usage de ChatGPT en mode ad hoc pour résumer des politiques, ou plugins Copilot pour l'analyse de documents Office. Ces usages restent non

structurés, sans ancrage aux référentiels normatifs, sans traçabilité des sources, et inadaptés à un contexte professionnel d’audit où la précision et la justification des écarts sont indispensables.

Synthèse. Aucune solution existante ne combine simultanément une analyse automatisée de documents non structurés, une couverture multi-référentiels incluant la Loi 09-08, et une interface conversationnelle ancrée aux normes GRC. Cette lacune justifie la conception de GRC AI Analyzer.

1.5 Problématique du projet

L’analyse des rapports GRC présente une dualité trompeuse, illustrée par la métaphore de l’iceberg : ce qui est visible — le rapport rendu et la conformité déclarée, les recommandations transmises au client — ne représente qu’une infime partie du travail réel. La masse immergée, invisible au commanditaire, concentre l’essentiel de l’effort et des risques : des dizaines d’heures d’analyse manuelle, d’annotations dispersées et de relectures répétées ; une interprétation des normes qui varie selon l’expert, sans traçabilité des choix effectués ; et surtout, des risques non détectés et des priorités fixées à l’intuition, faute de temps ou de méthode. C’est précisément cette partie invisible qui constitue le terreau des non-conformités non identifiées et des recommandations incomplètes.

La problématique centrale peut dès lors être formulée comme suit :

Comment concevoir une plateforme intelligente capable d’automatiser l’analyse des rapports GRC hétérogènes (PDF, DOCX, XLSX), d’extraire les risques, d’évaluer la conformité vis-à-vis des référentiels ISO 27001, RGPD et Loi 09-08, et de fournir une interface conversationnelle exploitant le contenu analysé, tout en garantissant performance, fiabilité et sécurité ?

1.6 Solution envisagée

La solution proposée, baptisée **GRC AI Analyzer**, est une plateforme *full-stack* composée d’un module d’ingestion documentaire prenant en charge PDF, DOCX et XLSX, d’un pipeline d’analyse asynchrone mobilisant le LLM Mistral AI, d’un moteur de Retrieval Augmented Generation pour le chat conversationnel, et d’une interface utilisateur React pour la visualisation et l’export des résultats.

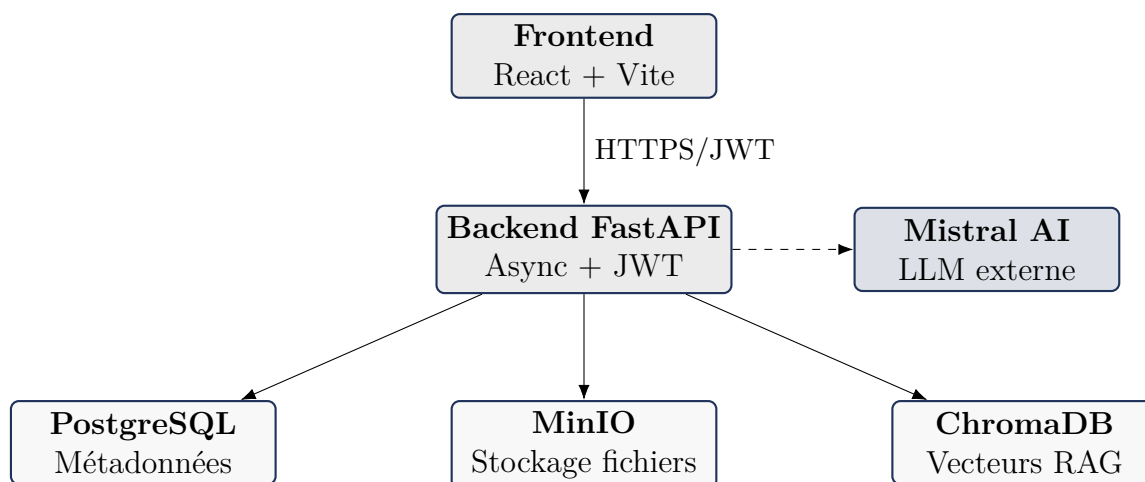


FIGURE 1.3 – Architecture simplifiée de la solution cible

1.7 Objectifs du projet

Le projet GRC AI Analyzer poursuit cinq objectifs complémentaires, couvrant l'ensemble de la chaîne de valeur de l'analyse documentaire GRC : de l'ingestion brute des documents jusqu'à la restitution des résultats aux décideurs.

1. Automatiser l'extraction des risques.

La plateforme doit être capable d'ingérer des documents hétérogènes (PDF, DOCX, XLSX) et d'en extraire automatiquement les risques mentionnés ou implicites, sans intervention manuelle. Cette automatisation vise à réduire le temps d'analyse de plusieurs jours à quelques minutes, tout en garantissant une couverture exhaustive du contenu.

2. Évaluer la conformité multi-référentiels.

Pour chaque document analysé, la plateforme doit produire une évaluation structurée des écarts de conformité vis-à-vis des trois référentiels retenus : ISO 27001 :2022, RGPD et Loi 09-08. Chaque écart doit être localisé, justifié et associé au contrôle normatif correspondant, offrant ainsi une traçabilité complète de l'analyse.

3. Générer des recommandations contextuelles.

Au-delà du diagnostic, la plateforme doit proposer des recommandations opérationnelles alignées sur les risques identifiés et le contexte spécifique de l'organisation analysée. Ces recommandations doivent être hiérarchisées par niveau de criticité et directement exploitables par les consultants dans leurs livrables.

4. Fournir une interface conversationnelle (RAG).

Un module de *Retrieval-Augmented Generation* doit permettre aux utilisateurs d'in-

terroger le rapport analysé en langage naturel : poser des questions précises sur un contrôle, demander la synthèse d'une section, ou explorer les non-conformités selon un axe thématique. Cette interface transforme le rapport statique en une base de connaissances dynamique et interrogeable.

5. Permettre l'export des résultats.

Les résultats de l'analyse doivent pouvoir être exportés sous des formats exploitables en contexte professionnel : rapport de synthèse en PDF mis en page, et tableau de bord de conformité au format Excel. Ces exports sont destinés aux comités de pilotage et aux responsables conformité, et doivent refléter fidèlement la structure et la terminologie des référentiels couverts.

Convergence des objectifs. Ces cinq objectifs forment un pipeline cohérent : l'extraction alimente l'évaluation, qui fonde les recommandations, que l'interface conversationnelle rend explorable, et que l'export matérialise en livrables. Chaque composant de la plateforme correspond directement à l'un de ces objectifs.

1.8 Conduite du projet

La conduite du projet s'appuie sur une approche **Agile Scrum**, avec un découpage en sprints fonctionnels permettant des livraisons incrémentales.



FIGURE 1.4 – Processus général de la méthode Agile Scrum appliquée au projet

1.9 Conclusion

Ce chapitre a permis de présenter le cadre général du projet. L'étude de l'existant a montré la nécessité d'une solution intelligente, automatisée et adaptée au contexte marocain. Le chapitre suivant sera consacré à l'analyse fonctionnelle détaillée.

2. Etude et Analyse de L'existant

Introduction

Ce chapitre présente la démarche de conception qui a guidé le développement de la plateforme GRC AI Analyzer. Après avoir établi le contexte métier et la problématique dans les chapitres précédents, il s'agit ici de traduire les exigences opérationnelles en artefacts de conception formels : analyse des besoins fonctionnels et non fonctionnels, diagramme des cas d'utilisation, diagramme de classes, diagramme de séquence et diagramme d'activité. Ces modèles constituent la référence conceptuelle de toute la phase d'implémentation.

2.1 Analyse des Besoins

2.1.1 Identification des acteurs

La plateforme GRC AI Analyzer implique trois acteurs principaux dont les périmètres d'action sont distincts :

- **L'Analyste GRC** — acteur central du système. Il uploades les rapports (PDF, DOCX, XLSX), déclenche les analyses, consulte les résultats (matrice des risques, taux de conformité, recommandations), interagit avec l'assistant RAG et exporte les livrables.
- **L'Encadrant / Manager** — profil à accès en lecture. Il consulte le tableau de bord, visualise le score de maturité GRC global, suit l'avancement des recommandations et accède aux rapports d'analyse générés par les analystes.
- **L'Administrateur** — responsable de la gouvernance applicative. Il gère les comptes utilisateurs (création, attribution des rôles ADMIN / ANALYSTE), consulte la piste d'audit et peut configurer les référentiels de conformité.
- **Mistral AI** — acteur externe (API tierce). Le modèle `mistral-large-latest` est sollicité pour l'extraction des risques, les vérifications de conformité, la génération des recommandations et la production du résumé exécutif.

2.1.2 Besoins fonctionnels

Les besoins fonctionnels ont été organisés en cinq modules cohérents :

Module 1 — Gestion des rapports

- **BF-01** : L'analyste doit pouvoir uploader un fichier au format PDF, DOCX ou XLSX dont la taille ne dépasse pas la limite configurée. Le système valide l'extension et rejette tout format non supporté.
- **BF-02** : Le système enregistre les métadonnées du rapport (nom, format, date d'upload, statut) dans la base de données et stocke le fichier binaire sur le serveur de fichiers local.
- **BF-03** : L'analyste peut consulter l'historique de ses rapports et filtrer par statut (*en_attente*, *en_cours*, *termine*, *erreur*).
- **BF-04** : L'analyste peut supprimer un rapport, ce qui entraîne la suppression en cascade des analyses associées, des fichiers physiques et des collections vectorielles ChromaDB correspondantes.

Module 2 — Analyse IA automatisée

- **BF-05** : À partir d'un rapport uploadé, l'analyste peut lancer une analyse automatique. L'API répond immédiatement (HTTP 202) et l'analyse s'exécute en tâche de fond.
- **BF-06** : Le système extrait le texte brut du document (page par page pour PDF via PyMuPDF, paragraphe par paragraphe pour DOCX via python-docx, feuille par feuille pour XLSX via openpyxl).
- **BF-07** : Le système découpe le texte en fragments (*chunks*) de 1 500 caractères avec un chevauchement de 200 caractères, puis les indexe dans ChromaDB via le modèle d'embedding multilingue **paraphrase-multilingual-MiniLM-L12-v2**.
- **BF-08** : Le système extrait les risques de manière exhaustive : chaque alerte, vulnérabilité, écart ou finding du document constitue un risque distinct, caractérisé par un libellé, une description technique, une catégorie (*CYBER*, *OPERATIONNEL*, *LEGAL*, *FINANCIER*, *RH*), une probabilité (1-5), un impact (1-5) et un score calculé (probabilité $\times$ impact).
- **BF-09** : La sévérité est déterminée automatiquement selon les seuils : score $\geq 20 \rightarrow$ CRITIQUE ; $\geq 12 \rightarrow$ ÉLEVÉ ; $\geq 6 \rightarrow$ MOYEN ; $< 6 \rightarrow$ FAIBLE.
- **BF-10** : Le système vérifie la conformité du document par rapport à trois référentiels en parallèle : ISO 27001 :2013 (14 domaines de l'Annexe A), RGPD (12 domaines), Loi 09-08 marocaine (11 domaines). Chaque domaine reçoit un statut (CONFORME / PARTIEL / NON_CONFORME) et un taux de conformité.
- **BF-11** : Le système génère une recommandation priorisée pour chaque risque identifié, incluant un type d'action (*QUICK_WIN* ou *LONG_TERME*) et un effort estimé (*FAIBLE*, *MOYEN*, *ÉLEVÉ*).

- **BF-12** : Le système produit un résumé exécutif structuré (350-450 mots), destiné à un CISO, synthétisant les conclusions clés, les risques prioritaires, l'état de conformité et les actions immédiates recommandées.
- **BF-13** : Le score de maturité GRC global est calculé comme la moyenne arithmétique des taux de conformité des trois référentiels.

Module 3 — Consultation et visualisation

- **BF-14** : L'analyste peut consulter la matrice des risques (visualisation Probabilité × Impact) via un composant Recharts dédié.
- **BF-15** : L'analyste peut visualiser le taux de conformité par référentiel via un radar chart (composant ComplianceRadar).
- **BF-16** : L'analyste peut lire les recommandations classées par priorité (CRITIQUE → HAUTE → MOYENNE → FAIBLE) et mettre à jour leur statut de traitement (À_FAIRE → EN_COURS → CLÔTURÉ).
- **BF-17** : Le tableau de bord affiche un score de maturité global, le nombre de risques par sévérité et les taux de conformité de la dernière analyse.

Module 4 — Assistant RAG conversationnel

- **BF-18** : L'analyste peut poser des questions en langage naturel (français ou anglais) sur le contenu du rapport. Le système récupère les 5 fragments les plus pertinents dans ChromaDB par similarité cosinus, construit un contexte et interroge Mistral pour générer une réponse sourcée.
- **BF-19** : Les réponses du chat citent explicitement les extraits du rapport sur lesquels elles s'appuient.

Module 5 — Export

- **BF-20** : L'analyste peut exporter l'analyse complète en PDF (rapport structuré avec page de couverture, résumé exécutif, tableau des risques, résultats de conformité et recommandations), généré via ReportLab.
- **BF-21** : L'analyste peut exporter le registre des risques en fichier Excel (.xlsx) avec quatre onglets (Résumé, Risques, Conformité, Recommandations), généré via XlsxWriter avec mise en forme conditionnelle par sévérité.

Module 6 — Authentification et administration

- **BF-22** : Le système implémente une authentification par JWT (JSON Web Token). Le token est signé avec l'algorithme HS256, stocké côté client dans le *localStorage* via Zustand, et transmis dans l'en-tête **Authorization: Bearer** à chaque requête.
- **BF-23** : Les mots de passe sont hachés avec bcrypt avant stockage. La vérification à la connexion compare le hash stocké sans jamais manipuler le mot de passe en clair.
- **BF-24** : L'administrateur peut créer et gérer les utilisateurs, leur attribuer le rôle ADMIN ou ANALYSTE. Un analyste ne peut accéder qu'à ses propres rapports ; un administrateur a une vue globale.

2.1.3 Besoins non fonctionnels

Performance et scalabilité

- **BNF-01** : L'API doit répondre aux requêtes de consultation en moins de 500 ms en conditions normales. L'upload et le déclenchement de l'analyse retournent immédiatement (HTTP 202) sans bloquer le client.
- **BNF-02** : Le pipeline d'analyse exploite la concurrence via `asyncio.gather` : l'indexation ChromaDB, l'extraction des risques et les trois vérifications de conformité s'exécutent en parallèle (Phase 1) ; la génération des recommandations et du résumé exécutif s'exécutent elles aussi en parallèle (Phase 2).
- **BNF-03** : Les appels à l'API Mistral sont sérialisés par un sémaphore global (`asyncio.Semaphore(1)`) avec un délai minimum de 1,5 seconde entre appels consécutifs pour respecter les limites de débit (*rate limits*). Un mécanisme de backoff exponentiel gère les erreurs HTTP 429 (délai de 30 s × numéro de tentative).

Fiabilité et résilience

- **BNF-04** : L'indexation RAG dans ChromaDB est *non-bloquante* : un échec de ChromaDB n'interrompt pas l'analyse, la plateforme continue sans fonctionnalité de chat.
- **BNF-05** : En cas d'erreur dans le pipeline, le statut de l'analyse est mis à jour en *erreur* dans la base de données et l'erreur est journalisée via Loguru, sans lever d'exception non gérée.
- **BNF-06** : Toutes les sessions de base de données du pipeline asynchrone s'exécutent dans un contexte transactionnel dédié (`AsyncSessionLocal`), distinct de la session HTTP, pour éviter tout conflit de concurrence.

Sécurité

- **BNF-07** : Toutes les routes API (sauf `/auth/login` et `/auth/register`) sont protégées par la dépendance `get_current_user` qui vérifie la validité du JWT.
- **BNF-08** : Les tokens JWT ont une durée de vie de 480 minutes (8 heures). Un intercepteur Axios côté frontend invalide la session locale dès réception d'une réponse HTTP 401.
- **BNF-09** : La politique CORS est configurée explicitement pour n'autoriser que l'origine du frontend (`localhost:5173` en développement, URL configurable en production).

Maintenabilité et extensibilité

- **BNF-10** : L'architecture adopte une séparation stricte des responsabilités : les routes FastAPI sont de simples façades, toute la logique métier réside dans la couche `services/`, et la logique IA dans la couche `ai/`.
- **BNF-11** : Les migrations de base de données sont gérées par Alembic, permettant des évolutions du schéma sans perte de données.
- **BNF-12** : Les prompts Mistral sont externalisés dans des modules dédiés (`risk_prompts.py`, `compliance_prompts.py`, `recommendation_prompts.py`, `summary_prompts.py`), facilitant leur maintenance et leur amélioration indépendante.

Internationalisation

- **BNF-13** : Le modèle d'embedding `paraphrase-multilingual-MiniLM-L12-v2` supporte 50+ langues, permettant l'analyse de documents en français, anglais ou arabe. L'assistant RAG répond dans la langue de la question posée.

2.2 Diagramme des Cas d'Utilisation

2.2.1 Description générale

Le diagramme des cas d'utilisation (figure 2.1) représente l'ensemble des interactions fonctionnelles entre les acteurs et le système GRC AI Analyzer. Il s'organise en six packages fonctionnels qui correspondent aux modules identifiés lors de l'analyse des besoins.

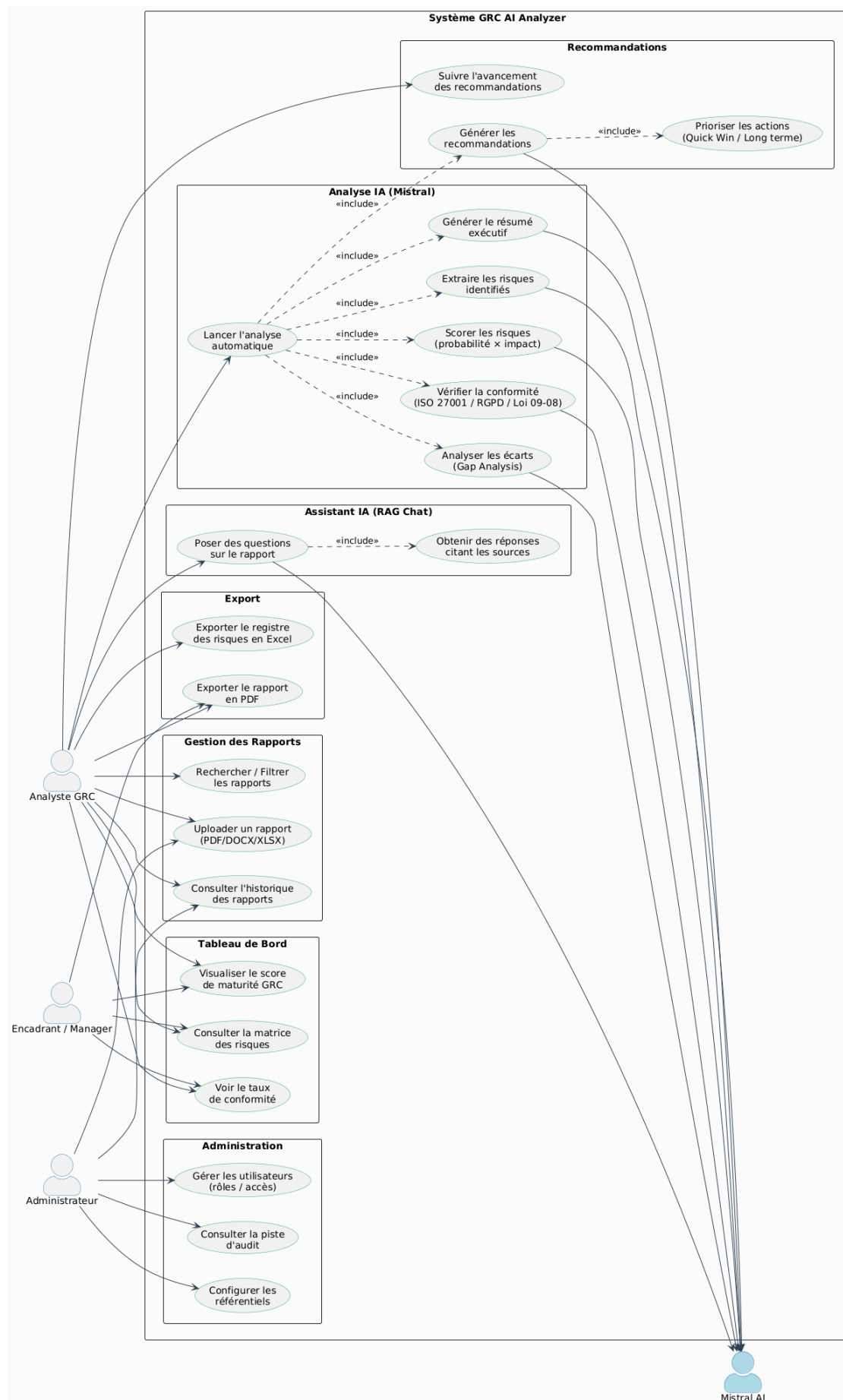


FIGURE 2.1 – Diagramme des cas d'utilisation — GRC AI Analyzer

2.2.2 Description des cas d'utilisation principaux

UC-01 : Uploader un rapport

UC-01 — Uploader un rapport

Acteur principal : Analyste GRC

Précondition : L'analyste est authentifié.

Scénario nominal :

1. L'analyste sélectionne un fichier (PDF, DOCX ou XLSX) via l'interface.
2. Le système valide le format (`validate_file_format`).
3. Le fichier est sauvegardé sur le serveur sous `uploads/reports/{uuid}/{nom}`.
4. Un enregistrement **Rapport** est créé en base avec le statut *en_attente*.
5. L'API retourne l'identifiant du rapport (HTTP 201).

Exception : Format non supporté → HTTP 400 avec message d'erreur.

UC-02 : Lancer l'analyse automatique

UC-02 — Lancer l'analyse automatique

Acteur principal : Analyste GRC

Acteur secondaire : Mistral AI

Précondition : Un rapport au statut *en_attente* existe.

Scénario nominal :

1. L'analyste déclenche l'analyse via `POST /api/v1/analyses/lancer/{rapport_id}`.
2. Le système crée un enregistrement **Analyse** (statut *en_cours*) et retourne immédiatement HTTP 202.
3. En tâche de fond : extraction du texte, chunking, indexation ChromaDB, extraction des risques et vérifications de conformité (Phase 1 parallèle), puis recommandations et résumé (Phase 2 parallèle).
4. L'analyse est marquée *terminé* à la fin du pipeline.

Cas inclus : Extraire les risques identifiés ; Scorer les risques ; Vérifier la conformité ; Analyser les écarts (Gap Analysis) ; Générer le résumé exécutif.

UC-03 : Poser des questions via le Chat IA

UC-03 — Poser des questions sur le rapport (RAG Chat)

Acteur principal : Analyste GRC

Acteur secondaire : Mistral AI

Précondition : L'analyse est terminée et les chunks ont été indexés.

Scénario nominal :

1. L'analyste saisit une question dans l'onglet Assistant RAG.
2. Le système encode la question via le modèle sentence-transformer.
3. ChromaDB retourne les 5 chunks les plus proches par similarité cosinus.
4. Le système construit le prompt contextuel et interroge Mistral.
5. La réponse est affichée avec les extraits sources cités.

Cas inclus : Obtenir des réponses citant les sources.

UC-04 : Exporter les livrables

L'analyste peut exporter deux types de livrables depuis l'interface :

- **Export PDF** — rapport d'analyse complet généré par ReportLab, comprenant une page de couverture avec score de maturité, un résumé exécutif, un tableau des risques avec badges de sévérité colorés, les résultats de conformité par référentiel et le plan de recommandations.
- **Export Excel** — registre des risques au format XLSX (XlsxWriter) avec quatre onglets structurés et mise en forme conditionnelle par sévérité et priorité.

UC-05 : Suivre l'avancement des recommandations

L'analyste peut faire progresser le statut de chaque recommandation via l'interface (bouton de cycle d'état) : *À_FAIRE* → *EN_COURS* → *CLÔTURÉ*, en appelant `PATCH /api/v1/recommandations/{id}/statut`.

2.3 Diagramme de Classes

2.3.1 Vue d'ensemble

Le diagramme de classes (figure 2.2) modélise les entités persistantes du domaine et leurs relations. Il reflète fidèlement le schéma de base de données PostgreSQL géré par

SQLAlchemy (ORM asynchrone) et versionné via Alembic.

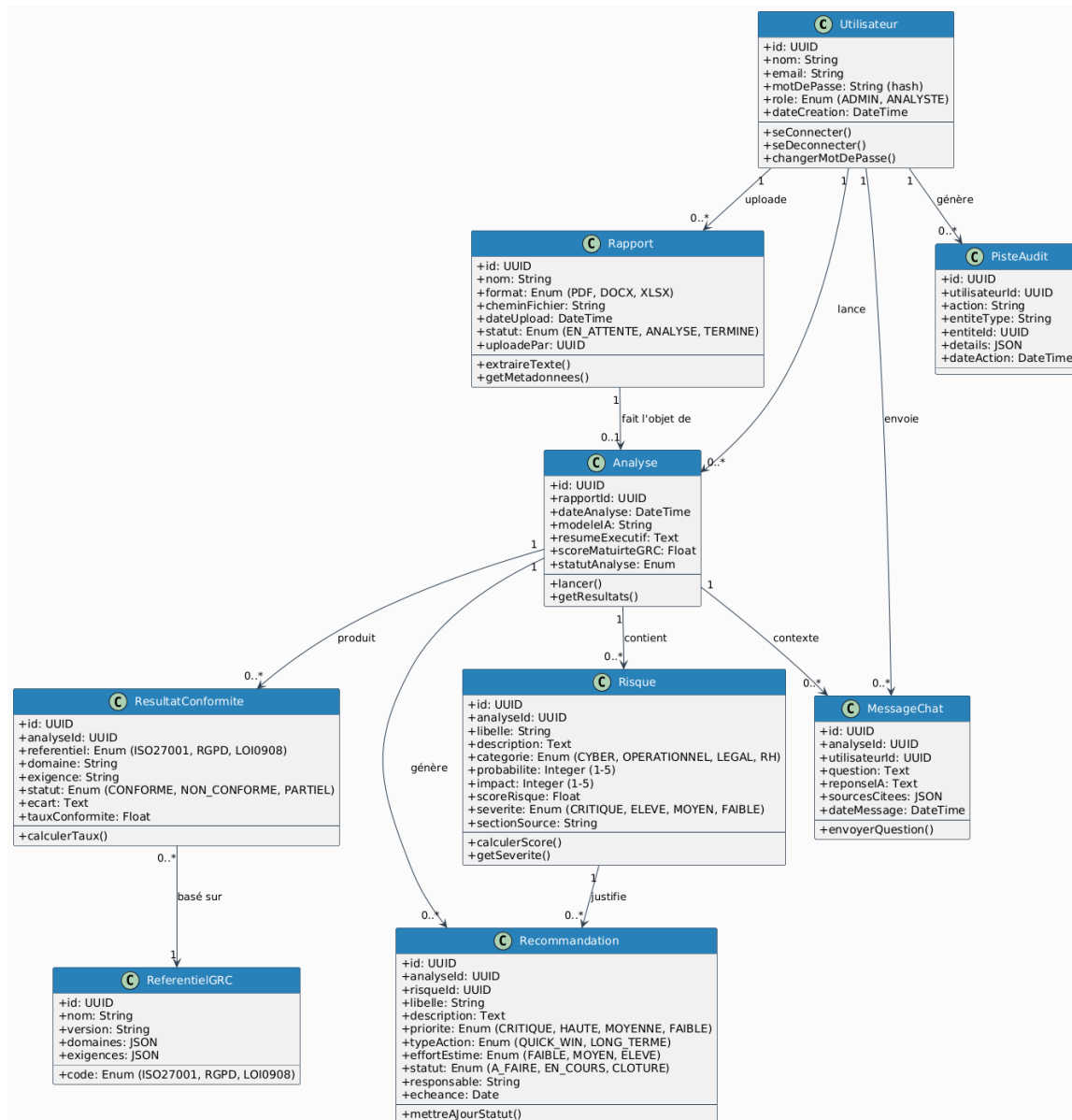


FIGURE 2.2 – Diagramme de classes — modèle du domaine GRC AI Analyzer

2.3.2 Description des classes principales

Utilisateur

La classe `Utilisateur` représente les comptes de la plateforme. Chaque utilisateur possède un identifiant `UUID`, un nom, un email unique (indexé), un mot de passe haché (bcrypt), un rôle énuméré (`ADMIN` ou `ANALYSTE`) et une date de création. Un utilisateur peut uploader plusieurs rapports et déclencher plusieurs analyses (relations *one-to-many*).

Rapport

La classe **Rapport** encapsule les métadonnées d'un document soumis à analyse. Elle stocke le nom du fichier, le format (**pdf**, **docx**, **xlsx**), le chemin de stockage sur disque (chaîne de type **reports/{uuid}/{nom}**), et le statut du cycle de vie (*en_attente* → *en_cours* → *terminé* ou *erreur*). La suppression d'un rapport entraîne la suppression en cascade de toutes ses analyses associées (**cascade="all, delete-orphan"**).

Analyse

La classe **Analyse** constitue le cœur du modèle. Elle est liée à un rapport (many-to-one) et à un utilisateur déclencheur. Elle porte le résumé exécutif (texte libre), le score de maturité GRC (flottant entre 0 et 100), et le statut de traitement. Elle agrège en composition les risques, les résultats de conformité et les recommandations.

Risque

La classe **Risque** représente une menace, vulnérabilité ou écart identifié par Mistral dans le document. Ses attributs clés sont :

- **libelle** — intitulé du risque (500 caractères max)
- **categorie** — taxonomie en cinq valeurs : CYBER, OPERATIONNEL, LEGAL, FINANCIER, RH
- **probabilite** et **impact** — entiers de 1 à 5
- **score_risque** — produit probabilité × impact (flottant)
- **severite** — calculée automatiquement selon les seuils définis dans **compute_severity()**
- **section_source** — référence à l'identifiant ou à la section du document source (ex. : « Finding #3 », « Section A.12 »)

ResultatConformite

La classe **ResultatConformite** enregistre l'évaluation d'un domaine de conformité pour un référentiel donné. Ses attributs principaux sont le référentiel (**ISO27001**, **RGPD**, **LOI0908**), le nom du domaine évalué, le statut (**CONFORME** / **NON_CONFORME** / **PARTIEL**), l'écart constaté (texte libre) et le taux de conformité (flottant). Une analyse peut produire jusqu'à 37 enregistrements de conformité (14 domaines ISO + 12 RGPD + 11 Loi 09-08).

Recommandation

La classe **Recommandation** modélise une action corrective générée par Mistral en réponse à un risque. Elle est liée optionnellement à un risque (**risque_id** nullable), permettant la traçabilité risque-recommandation. Ses attributs incluent : la priorité (CRITIQUE / HAUTE / MOYENNE / FAIBLE), le type d'action (QUICK_WIN ou LONG_TERME), l'effort estimé (FAIBLE / MOYEN / ÉLEVÉ) et le statut de traitement (À_FAIRE / EN_COURS / CLÔTURÉ).

MessageChat

La classe **MessageChat** (présente dans le modèle conceptuel) stocke l'historique des interactions conversationnelles : la question posée par l'utilisateur, la réponse générée par Mistral et les sources citées (tableau JSON des extraits ChromaDB).

ReferentielGRC

La classe **ReferentielGRC** représente la configuration des cadres normatifs : ISO 27001, RGPD et Loi 09-08. Elle stocke le code du référentiel, sa version, et la liste de ses domaines et exigences au format JSON.

PisteAudit

La classe **PisteAudit** enregistre les actions réalisées par les utilisateurs (upload, lancement d'analyse, modification de statut), permettant à l'administrateur de tracer les opérations sensibles via le type d'entité, l'identifiant de l'entité concernée et les détails en JSON.

2.3.3 Relations entre classes

Le tableau suivant résume les relations de cardinalité du modèle :

TABLE 2.1 – Relations entre les classes du domaine

Classe source	Relation	Classe cible	Description
Utilisateur	1..* (uploade)	Rapport	Un utilisateur peut soumettre plusieurs rapports
Utilisateur	1..* (lance)	Analyse	Un utilisateur peut déclencher plusieurs analyses
Rapport	0..1 (fait l'objet de)	Analyse	Un rapport peut être analysé une fois à la fois
Analyse	0..* (contient)	Risque	Une analyse produit N risques
Analyse	0..* (produit)	ResultatConformite	Une analyse produit jusqu'à 37 résultats de conformité
Analyse	0..* (génère)	Recommandation	Une analyse génère une recommandation par risque
Analyse	0..* (contexte)	MessageChat	Une analyse peut faire l'objet de N questions RAG
Risque	0..* (justifie)	Recommandation	Un risque peut être lié à une ou plusieurs recommandations
ResultatConformite	basé sur	ReferentielGRC	Les résultats référencent un cadre normatif
Utilisateur	0..* (génère)	PisteAudit	Les actions utilisateur alimentent la piste d'audit

2.4 Diagramme de Séquence

2.4.1 Séquence principale : Analyse d'un rapport GRC

Le diagramme de séquence (figure 2.3) décrit les interactions chronologiques entre les composants lors de l'opération la plus complexe du système : le lancement et l'exécution complète d'une analyse IA.

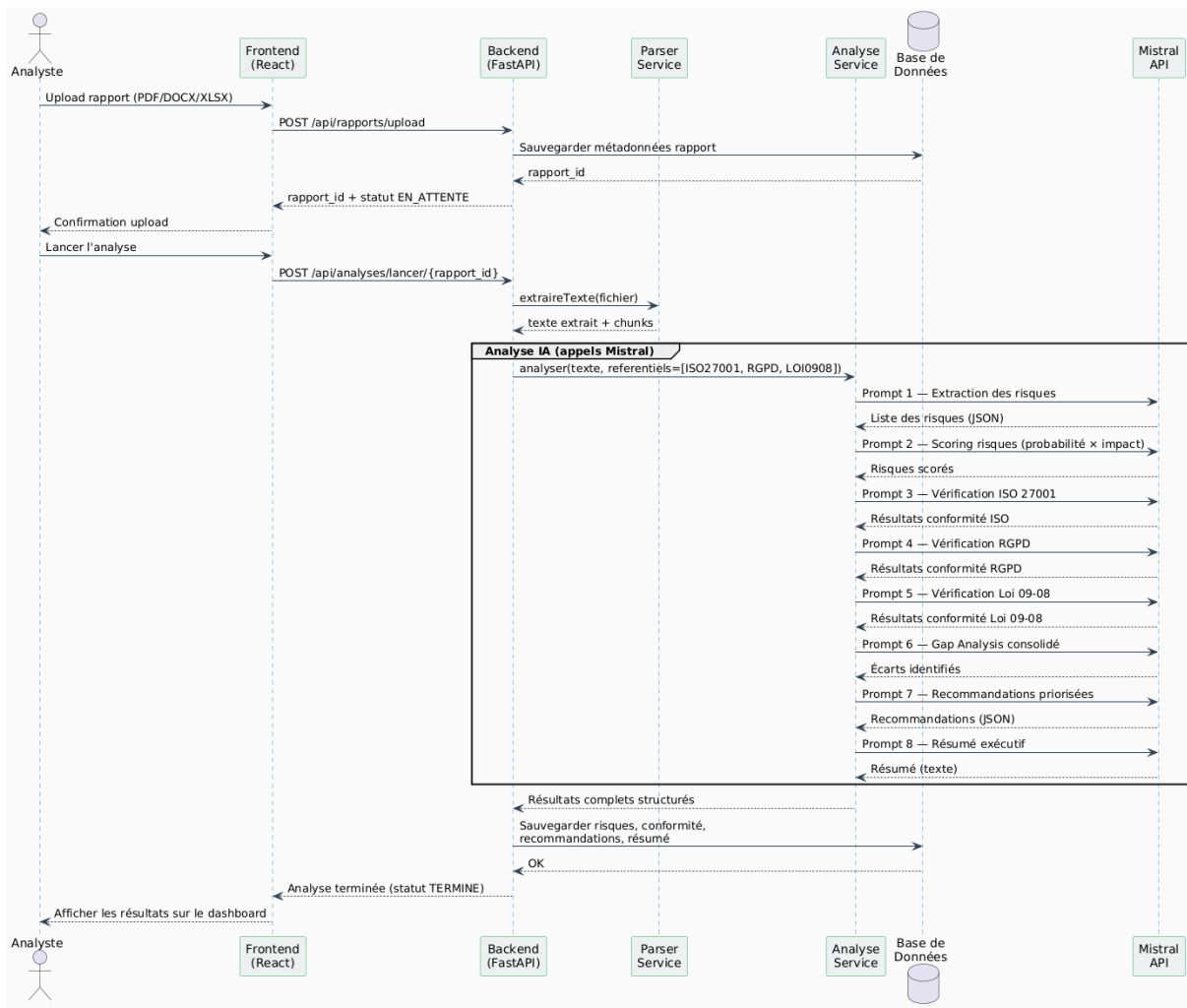


FIGURE 2.3 – Diagramme de séquence — Analyse d'un rapport GRC

2.4.2 Description détaillée des interactions

Le flux se décompose en deux grandes phases, séparées par une frontière asynchrone matérialisée par la réponse HTTP 202.

Phase synchrone : Upload et déclenchement

1. L'analyste soumet son fichier depuis le frontend React via `POST /api/rapports/upload`. Axios joint le token JWT dans l'en-tête de la requête.

2. Le backend FastAPI valide le format du fichier et délègue au `report_service` qui sauvegarde le fichier sur disque et crée l'enregistrement **Rapport** en base de données (statut : *en_attente*).
3. Le frontend reçoit le `rapport_id` et affiche une confirmation d'upload.
4. L'analyste déclenche l'analyse via `POST /api/analyses/lancer/{rapport_id}`.
5. Le backend crée immédiatement l'enregistrement **Analyse** (statut : *en_cours*), enregistre la tâche de fond via `BackgroundTasks`, et retourne HTTP 202 avec l'`analyse_id`.

Phase asynchrone : Pipeline IA (8 appels Mistral)

Le service `analysis_service.run_analysis()` s'exécute dans une session SQLAlchemy dédiée. Il suit le pipeline suivant :

1. **Extraction du texte** — le fichier est lu depuis le disque et parsé selon son format. Le texte brut est découpé en chunks.
2. **Phase 1 — Parallélisation via `asyncio.gather` :**
 - Indexation ChromaDB (embedding des chunks en mémoire)
 - Prompt 1 → Mistral : extraction exhaustive des risques (JSON structuré)
 - Prompt 2 → Mistral : scoring probabilité × impact des risques
 - Prompt 3 → Mistral : vérification conformité ISO 27001 (14 domaines)
 - Prompt 4 → Mistral : vérification conformité RGPD (12 domaines)
 - Prompt 5 → Mistral : vérification conformité Loi 09-08 (11 domaines)Les résultats sont validés (sévérités, catégories, doublons) et persistés en base de données.
3. **Gap Analysis consolidée** — à partir des taux de conformité calculés, le score de maturité global est déterminé (moyenne des trois référentiels).
4. **Phase 2 — Parallélisation via `asyncio.gather` :**
 - Prompt 7 → Mistral : génération des recommandations priorisées (une par risque identifié)
 - Prompt 8 → Mistral : génération du résumé exécutif (350-450 mots, structuré en 6 sections)
5. **Sauvegarde finale** — l'enregistrement **Analyse** est mis à jour avec le résumé, le score de maturité et le statut *terminé*.

Phase de consultation

Le frontend React interroge `GET /api/analyses/{id}` toutes les 4 secondes (polling) jusqu'à obtenir le statut *terminé*. À ce moment, trois requêtes parallèles (`Promise.all`)

recupèrent les risques, les résultats de conformité et les recommandations, qui sont affichés dans les onglets correspondants de la page d'analyse.

2.5 Diagramme d'Activité

2.5.1 Vue d'ensemble du flux de traitement

Le diagramme d'activité (figure 2.4) modélise le flux de contrôle complet du système, de l'upload du rapport jusqu'à la consultation des résultats et l'export des livrables. Il met en évidence les deux zones de parallélisme (swimlanes horizontaux) correspondant aux deux phases du pipeline IA.



FIGURE 2.4 – Diagramme d'activité — flux de traitement GRC AI Analyzer

2.5.2 Description des activités

Bloc 1 — Préparation du document

Les quatre premières activités forment une séquence linéaire :

1. **Upload du rapport** — l'analyste soumet son fichier PDF/DOCX/XLSX via l'interface. Le système valide le format, sauvegarde le fichier et enregistre les métadonnées.
2. **Extraction et nettoyage du texte** — selon le format détecté, l'un des trois parsers est appelé (PyMuPDF pour PDF, python-docx pour DOCX, openpyxl pour XLSX). Le texte est extrait structuré par page, paragraphe ou cellule.
3. **Découpage en chunks** — le texte est fragmenté en segments de 1 500 caractères avec un chevauchement de 200 caractères assurant la continuité sémantique.
4. **Génération des embeddings** — chaque chunk est transformé en vecteur dense de 384 dimensions par le modèle `paraphrase-multilingual-MiniLM-L12-v2` et indexé dans ChromaDB dans une collection nommée `analyse_{id}`.

Bloc 2 — Analyse IA parallèle (Phase 1)

Un nœud de fourche (*fork*) déclenche simultanément quatre activités parallèles, matérialisant l'utilisation de `asyncio.gather` dans le code :

- **Extraction des risques (Mistral)** — appel JSON structuré retournant la liste des risques avec libellé, description, catégorie, probabilité, impact et référence source.
- **Scoring probabilité × impact** — calcul déterministe du score ($score = probabilité \times impact$) et classification automatique de la sévérité selon les seuils définis.
- **Vérification ISO 27001 (Mistral)** — évaluation des 14 domaines de l'Annexe A avec statut CONFORME/PARTIEL/NON_CONFORME et taux par domaine.
- **Vérification RGPD (Mistral)** — évaluation des 12 articles RGPD pertinents.
- **Vérification Loi 09-08 (Mistral)** — évaluation des 11 domaines de la loi marocaine de protection des données.

Un nœud de jonction (*join*) synchronise les cinq activités parallèles avant de passer à la consolidation.

Bloc 3 — Consolidation et génération (Phase 2)

1. **Consolidation gap analysis** — les taux de conformité sont agrégés, le score de maturité global est calculé.

2. **Génération des recommandations priorisées (Mistral) et génération du résumé exécutif (Mistral)** s'exécutent en parallèle.
3. **Sauvegarde en base de données** — tous les objets (risques, conformités, recommandations, résumé) sont persistés dans PostgreSQL.
4. **Mise à jour du tableau de bord** — le statut de l'analyse passe à *terminé*.

Décision : Risques critiques détectés ?

Après la mise à jour du tableau de bord, un nœud de décision vérifie la présence de risques de sévérité CRITIQUE (score ≥ 20). Si oui, une notification est envoyée à l'administrateur. Dans les deux cas, l'analyste est redirigé vers la page des résultats.

Bloc 4 — Consultation des résultats (parallèle)

L'analyste dispose de quatre vues accessibles simultanément via les onglets de l'interface :

- **Matrice des risques** — visualisation Probabilité $\times$ Impact via RiskMatrix (Recharts).
- **Taux de conformité par référentiel** — radar chart via ComplianceRadar (Recharts).
- **Recommandations** — plan d'action priorisé avec gestion du cycle de vie.
- **Chat IA** — assistant conversationnel RAG (Mistral + ChromaDB).

Puis l'analyste peut suivre l'avancement des recommandations au fil du temps.

Décision : Export nécessaire ?

Si l'analyste souhaite exporter, un nœud de fourche permet de générer en parallèle le rapport PDF (ReportLab) et/ou le registre Excel (XlsxWriter), avant de converger vers la fin du flux.

Conclusion

Ce chapitre a établi les fondements conceptuels de la plateforme GRC AI Analyzer. L'analyse des besoins a permis d'identifier 24 besoins fonctionnels répartis en six modules et 13 besoins non fonctionnels couvrant la performance, la fiabilité, la sécurité et la maintenabilité. Le diagramme des cas d'utilisation a formalisé les interactions entre les trois acteurs humains et le modèle Mistral AI. Le diagramme de classes a modélisé les

huit entités persistantes du domaine et leurs relations de composition et d'association. Le diagramme de séquence a détaillé les huit appels successifs à l'API Mistral orchestrés en deux phases de parallélisme. Enfin, le diagramme d'activité a retranscrit le flux complet du traitement, depuis l'upload jusqu'à l'export des livrables.

Ces artefacts constituent la référence pour le chapitre suivant, qui présentera l'implémentation concrète de la solution.

3. Conception technique et choix technologiques

Définition de l'architecture cible, structuration des couches applicatives, conception du pipeline IA et du moteur RAG, et justification des outils utilisés.

3.1 Introduction

Après l'analyse fonctionnelle, ce chapitre introduit la conception technique de la solution.

3.2 Vision générale de la solution cible

L'architecture cible repose sur une séparation nette entre la présentation (React), l'orchestration et la sécurité (FastAPI), les services IA (Mistral + ChromaDB) et la persistance (PostgreSQL + MinIO).

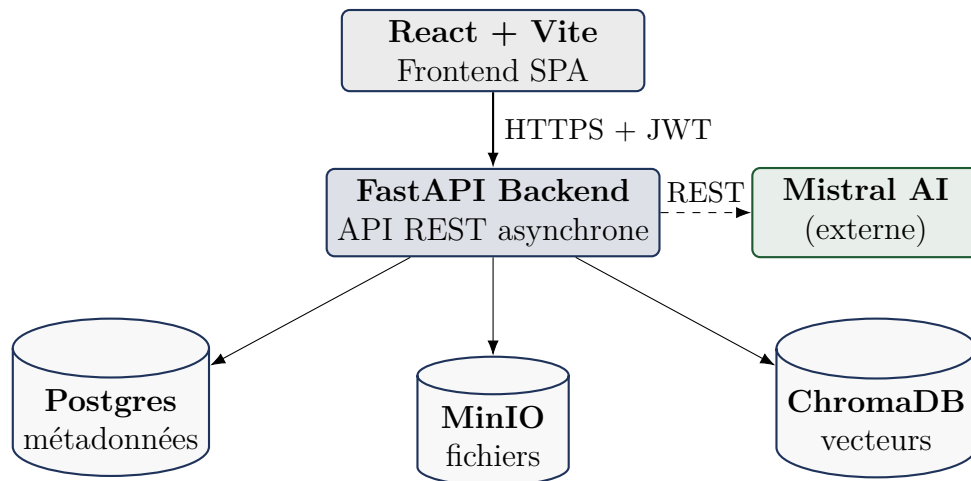


FIGURE 3.1 – Architecture globale de GRC AI Analyzer

3.2.1 Principes directeurs

1. **Découplage frontend/backend.** Le frontend React communique uniquement via une API REST.

2. **Asynchronisme natif.** FastAPI avec `async/await` et `asyncio.gather` permet d'exécuter en parallèle les appels IA.
3. **Pipeline d'analyse en arrière-plan.** L'analyse longue est exécutée dans un `BackgroundTask` avec sa propre session asynchrone.
4. **Sérialisation des appels Mistral.** Un `asyncio.Semaphore(1)` global évite les erreurs 429.
5. **Séparation des stockages.** Métadonnées dans PostgreSQL, fichiers dans MinIO, vecteurs dans ChromaDB.

3.3 Architecture en couches du backend

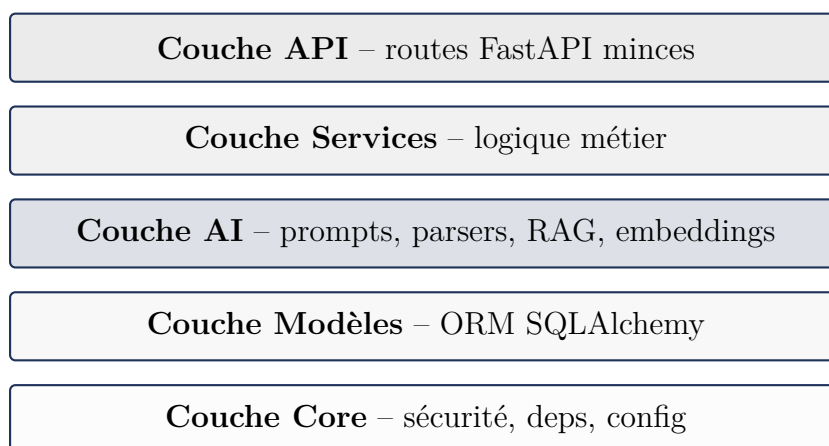


FIGURE 3.2 – Organisation en couches du backend FastAPI

3.4 Pipeline d'analyse asynchrone en deux phases

Le cœur technique du projet : l'analyse d'un rapport est décomposée en deux phases parallèles successives.

3.5 Modèle RAG

Le modèle d'embeddings retenu est `paraphrase-multilingual-MiniLM-L12-v2`, choisi pour ses bonnes performances multilingues et sa taille raisonnable.

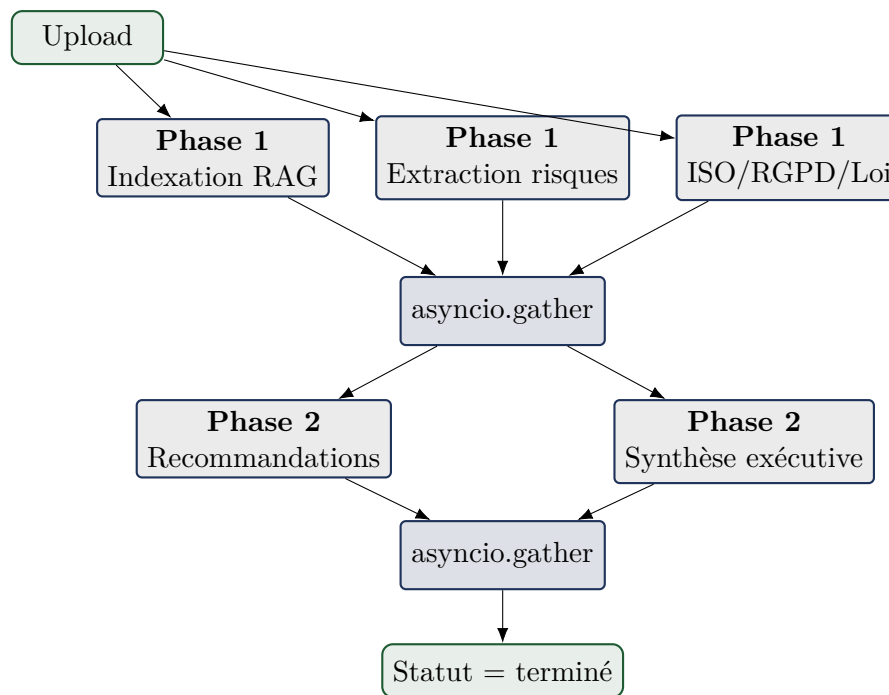


FIGURE 3.3 – Pipeline d’analyse en deux phases parallèles

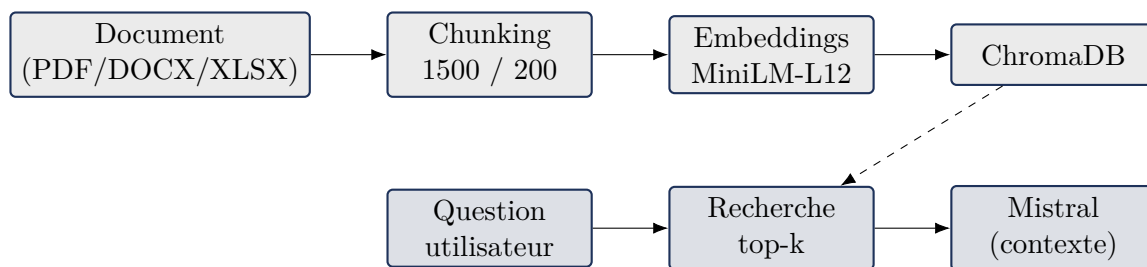


FIGURE 3.4 – Pipeline RAG : indexation et requête

3.6 Modèle de données (PostgreSQL)

Calcul de criticité d’un risque. La sévérité d’un risque est définie par :

$$\text{score} = \text{probabilité} \times \text{impact}, \quad (\text{probabilité}, \text{impact}) \in [1, 5]^2$$

avec les seuils : FAIBLE < 6, MOYEN < 12, ÉLEVÉ < 20, CRITIQUE ≥ 20 .

3.7 Choix technologiques

3.8 Principes de sécurité retenus

1. Hash des mots de passe avec bcrypt (cost 12).

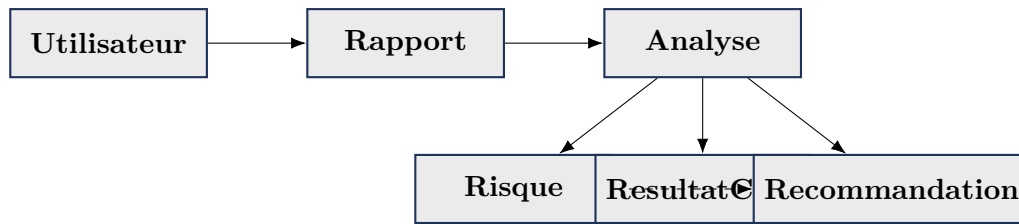


FIGURE 3.5 – Modèle relationnel simplifié

2. JWT signé HS256, expiration 24h, stocké côté client.
3. Validation stricte des entrées via Pydantic.
4. Limitation des types de fichiers et taille maximale (50 MB).
5. Isolation des analyses par utilisateur.
6. Variables sensibles externalisées dans `.env`.

3.9 Conclusion

La conception technique repose sur une architecture en couches asynchrone, un pipeline IA parallélisé et un modèle RAG basé sur des embeddings multilingues.

Catégorie	Outil retenu	Justification
Frontend	React 18 + Vite	SPA performante, écosystème riche
UI Library	Tailwind / shadcn	Design moderne, customisable
Charts	Recharts	Composants React natifs
État global	Zustand	Simple, léger
HTTP	Axios + interceptor	Gestion JWT centralisée
Backend	FastAPI 0.110+	Async natif, Pydantic, OpenAPI auto
ORM	SQLAlchemy 2 + asyncpg	Async, mature
Migrations	Alembic	Référence Python
LLM	Mistral AI	Bon rapport qualité/prix, multilingue
Embeddings	sentence-transformers	Multilingue, léger
Vector DB	ChromaDB	Open-source, Python natif
Object Store	MinIO	Compatible S3
RDBMS	PostgreSQL 15	Robustesse, JSONB
PDF Parser	PyMuPDF	Rapide, qualité élevée
Auth	JWT + bcrypt	Standard, stateless

TABLE 3.1 – Synthèse des choix techniques

4. Sprint 1 : Authentification et gestion des utilisateurs

Mise en place du socle d'authentification, du contrôle d'accès basé sur les rôles, et des premiers écrans de connexion / inscription.

4.1 Introduction

Ce premier sprint pose le socle de la plateforme : sans authentification fiable, aucune fonctionnalité métier ne peut être exposée de manière sécurisée.

4.2 Objectifs et périmètre

- Inscription et connexion sécurisée.
- Génération et vérification de tokens JWT.
- Hash bcrypt des mots de passe.
- Modèle utilisateur et rôles RBAC.
- Interceptor Axios pour l'injection automatique du token.

4.3 Diagramme de séquence : connexion

4.4 Extrait de code : génération JWT

```
1 from datetime import datetime, timedelta
2 from jose import jwt
3 from passlib.context import CryptContext
4
5 pwd_context = CryptContext(schemes=["bcrypt"], deprecated="auto")
6
7 def hash_password(password: str) -> str:
8     return pwd_context.hash(password)
9
```

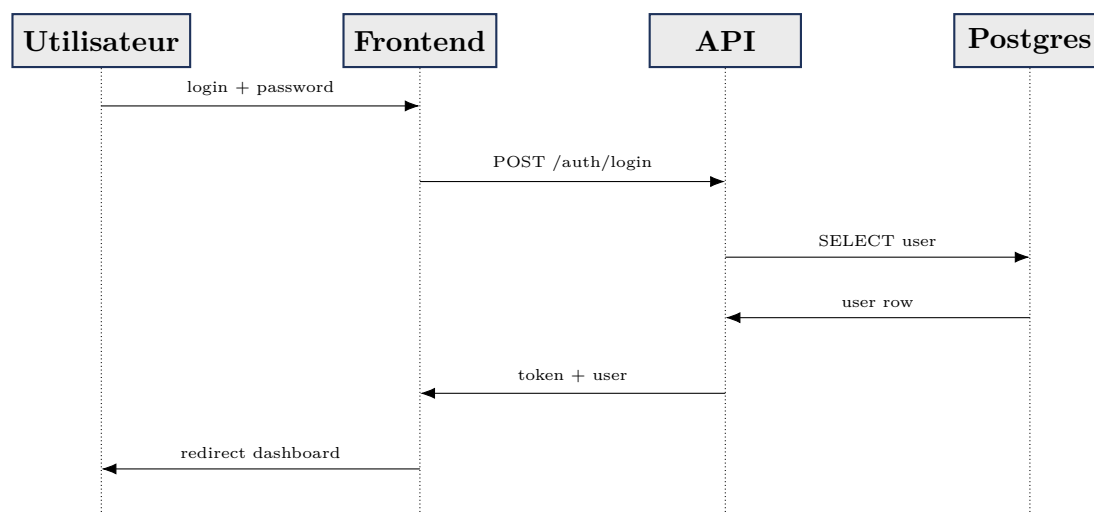


FIGURE 4.1 – Diagramme de séquence – Connexion JWT

```

10 def verify_password(plain: str, hashed: str) -> bool:
11     return pwd_context.verify(plain, hashed)
12
13 def create_access_token(data: dict, expires_delta: timedelta = None):
14     to_encode = data.copy()
15     expire = datetime.utcnow() + (expires_delta or timedelta(hours=24))
16     to_encode.update({"exp": expire})
17     return jwt.encode(to_encode, settings.SECRET_KEY, algorithm="HS256")

```

Listing 4.1 – Service d'authentification

4.5 Résultats fonctionnels

4.5.1 Interface de connexion

L'interface de connexion présente les champs email et mot de passe avec validation client. En cas d'erreur, un message contextualisé est affiché.

4.5.2 Interface d'inscription

L'inscription requiert nom complet, email, mot de passe et confirmation. Un compte est créé avec le rôle utilisateur par défaut.

4.5.3 Politique de mot de passe

La politique impose : minimum 8 caractères, au moins une majuscule, un chiffre et un caractère spécial.

4.6 Difficultés rencontrées

Difficulté	Solution apportée
Persistence du token côté client	Stockage localStorage + interceptor Axios pour injection automatique
CORS entre Vite (5173) et FastAPI (8000)	Configuration explicite de CORSMiddleware
Migrations Alembic sur Windows	Driver psycopg2 synchrone pour Alembic, asyncpg pour le runtime

TABLE 4.1 – Difficultés du Sprint 1 et solutions

4.7 Bilan du Sprint 1

Le sprint a permis de poser un socle d'authentification fiable, conforme aux standards (JWT, bcrypt, RBAC).

5. Sprint 2 : Upload et parsing documentaire

Mise en place du module d'ingestion documentaire : upload, validation, stockage MinIO et extraction de texte multi-format.

5.1 Introduction

Le second sprint adresse l'entrée du pipeline : transformer un fichier hétérogène en texte exploitable par le LLM.

5.2 Objectifs

- Upload multipart de fichiers PDF, DOCX, XLSX (max 50 MB).
- Déduplication par hash SHA-256.
- Stockage dans MinIO (bucket `grc-reports`).
- Extraction texte via PyMuPDF / python-docx / openpyxl.
- Création d'une entité Rapport en base.

5.3 Architecture du module

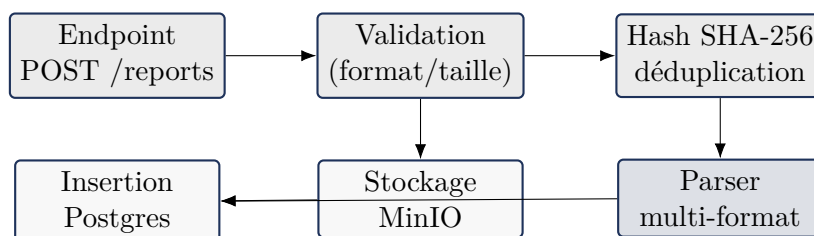


FIGURE 5.1 – Pipeline d'ingestion documentaire

5.4 Stratégies d'extraction par format

Format	Bibliothèque	Stratégie
PDF	PyMuPDF (fitz)	Extraction page-par-page, préservation de l'ordre
DOCX	python-docx	Itération sur paragraphes et tableaux
XLSX	openpyxl	Lecture de toutes les feuilles

TABLE 5.1 – Stratégies d'extraction par format documentaire

5.5 Chunking et préparation pour le RAG

Le texte extrait est découpé en chunks de 1500 caractères avec un overlap de 200 caractères, garantissant la continuité sémantique entre chunks adjacents.

```

1 def chunk_text(text: str, size: int = 1500, overlap: int = 200) -> list:
2     chunks, start = [], 0
3     while start < len(text):
4         end = min(start + size, len(text))
5         chunks.append(text[start:end])
6         start += size - overlap
7     return chunks

```

Listing 5.1 – Fonction de chunking

5.6 Bilan du Sprint 2

La plateforme accepte désormais des rapports hétérogènes et les prépare pour l'analyse IA, avec déduplication automatique.

6. Sprint 3 : Pipeline d'analyse IA

Coeur du projet : extraction des risques, évaluation de la conformité ISO 27001, RGPD et Loi 09-08 par appels parallèles à Mistral AI, puis génération des recommandations.

6.1 Introduction

Ce sprint constitue l'apport différenciant du projet : la transformation d'un texte non structuré en une analyse GRC structurée, exploitable et actionnable.

6.2 Architecture du pipeline

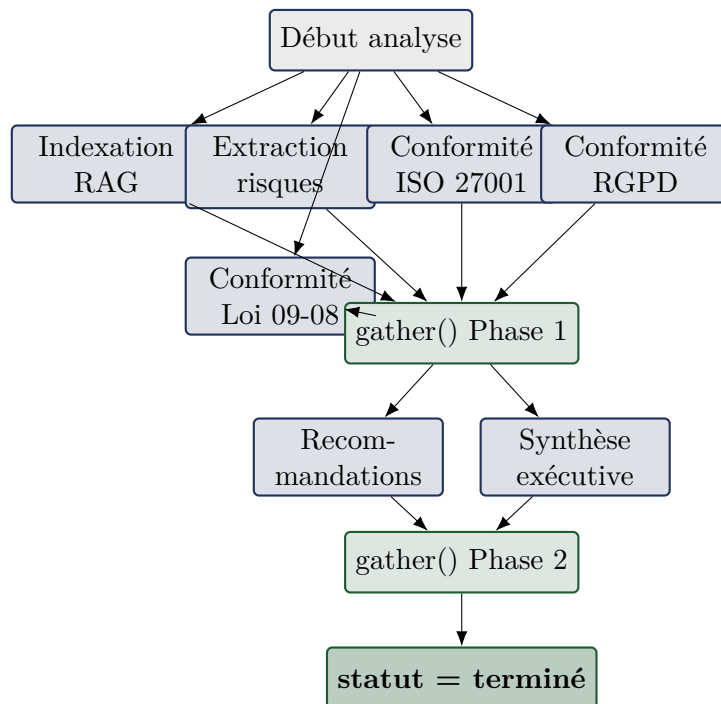


FIGURE 6.1 – Pipeline d'analyse en deux phases parallèles

6.3 Prompt engineering

Pour chaque type d'extraction, un prompt spécialisé est construit. Il comporte trois parties : un rôle system, le contexte, et un format JSON strict attendu en sortie.

```
1 def build_risk_prompt(text):
2     return [
3         {"role": "system", "content": "Tu es un expert GRC..."},
4         {"role": "user", "content": f"""
5 Analyse le rapport et extrait les risques en JSON :
6 {{
7     "risques": [
8         {{
9             "titre": "...",
10            "categorie": "operationnel|financier|technologique|reglementaire",
11            "probabilite": 1..5,
12            "impact": 1..5
13        }}
14    ]
15 }}
16
17 Rapport :
18 {text[:8000]}
19 """}
20 ]
```

Listing 6.1 – Prompt d'extraction de risques

6.4 Sérialisation des appels Mistral

```
1 import asyncio
2 from mistralai import Mistral
3
4 _semaphore = asyncio.Semaphore(1)
5 _client = Mistral(api_key=settings.MISTRAL_API_KEY)
6
7 async def call_mistral(messages, model="mistral-large-latest"):
8     async with _semaphore:
9         response = await _client.chat.complete_async(
10             model=model, messages=messages
11         )
12     return response.choices[0].message.content
```

Listing 6.2 – Sémaphore global anti rate-limit

6.5 Résultats

6.5.1 Matrice probabilité/impact des risques

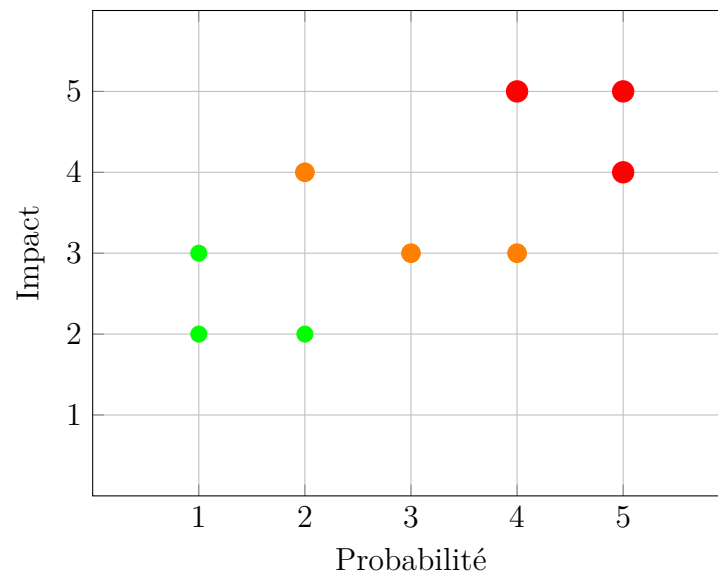


FIGURE 6.2 – Matrice probabilité/impact – exemple de visualisation des risques

6.5.2 Radar de conformité

Le radar de conformité affiche, pour chaque référentiel, le pourcentage de contrôles satisfaits, partiellement satisfaits ou non satisfaits.

6.6 Bilan du Sprint 3

Le pipeline IA produit des résultats structurés exploitables et réduit le temps d'analyse manuelle de plusieurs jours à moins de deux minutes par rapport.

7. Sprint 4 : RAG et chat conversationnel

Indexation vectorielle avec ChromaDB et mise en place d'une interface conversationnelle permettant d'interroger le rapport analysé en langage naturel.

7.1 Introduction

Au-delà de l'analyse figée, l'utilisateur souhaite pouvoir poser des questions ouvertes. Le RAG permet de répondre en mobilisant le contenu original du rapport.

7.2 Indexation vectorielle

À la fin de l'analyse, les chunks préparés au Sprint 2 sont vectorisés par `paraphrase-multilingual-M` et stockés dans une collection ChromaDB, garantissant l'isolation par analyse.

```
1 def index_chunks(analyse_id, chunks):
2     collection = chroma_client.get_or_create_collection(
3         f"analyse_{analyse_id}"
4     )
5     embeddings = embedder.encode(chunks).tolist()
6     collection.add(
7         ids=[f"chunk_{i}" for i in range(len(chunks))],
8         documents=chunks,
9         embeddings=embeddings
10    )
```

Listing 7.1 – Indexation ChromaDB

7.3 Pipeline de question-réponse

1. L'utilisateur saisit une question en langage naturel.
2. Le backend génère l'embedding de la question.
3. ChromaDB retourne les $k = 5$ chunks les plus similaires.

4. Un prompt augmenté est composé (question + extraits cités).
5. Mistral génère une réponse contextualisée en français.

7.4 Tolérance aux pannes

Si l'indexation ChromaDB échoue, l'analyse principale n'est pas bloquée : seule la fonctionnalité chat devient indisponible pour cette analyse.

7.5 Résultats

L'interface chat s'intègre dans la page d'analyse via un panneau latéral. L'utilisateur conserve l'historique de ses questions, et chaque réponse est accompagnée des passages sources cités.

8. Sprint 5 : Dashboards, exports et supervision

Visualisation des résultats, exports professionnels (PDF, Excel) et tableau d'administration.

8.1 Introduction

Après la production des données d'analyse, ce sprint se concentre sur leur exploitation par l'utilisateur final.

8.2 Tableau de bord utilisateur

La page d'analyse présente, pour une analyse terminée :

- synthèse exécutive ;
- matrice probabilité/impact des risques ;
- radar de conformité par référentiel ;
- liste paginable des risques avec filtres ;
- liste des recommandations associées.

8.3 Exports professionnels

Deux formats sont proposés :

- **PDF** (ReportLab) : structuré avec couverture, sommaire, sections risques, conformité, recommandations.
- **Excel** (openpyxl) : feuilles Risques, Conformité, Recommandations, avec formules et mise en forme conditionnelle.

8.4 Polling côté frontend

La page d'analyse interroge `GET /analyses/id` toutes les 3 secondes tant que le statut est `en_cours`. Dès que le statut bascule sur `termine`, le frontend lance en parallèle les requêtes vers les sous-ressources.

8.5 Tableau d'administration

L'administrateur dispose d'une vue globale : liste des utilisateurs, statistiques, supervision des analyses, et journaux d'audit.

Conclusion générale et perspectives

Bilan du projet

Ce projet de fin d'études a permis de concevoir, développer et déployer une plateforme full-stack d'analyse automatisée des rapports GRC, baptisée **GRC AI Analyzer**. La solution combine l'efficacité des LLM modernes (Mistral AI), la pertinence du Retrieval Augmented Generation et la robustesse d'une architecture asynchrone, pour transformer un processus manuel en un workflow automatisé en quelques minutes.

Les objectifs initiaux ont été atteints : la plateforme accepte des documents hétérogènes, extrait automatiquement les risques, évalue la conformité par rapport aux trois référentiels cibles (ISO 27001, RGPD, Loi 09-08), génère des recommandations contextualisées, propose un chat conversationnel et exporte les résultats.

Apports techniques

Sur le plan technique, le projet a permis d'approfondir la maîtrise de FastAPI en mode asynchrone, l'orchestration parallèle, l'intégration de LLM externes avec gestion fine du rate limiting, l'utilisation des bases vectorielles et la mise en place d'une architecture en couches claire.

Apports métier

Sur le plan métier, GRC AI Analyzer apporte un gain de productivité mesurable, une réduction des biais d'interprétation, une couverture multi-référentiels cohérente, et une capacité d'interrogation conversationnelle inédite.

Perspectives d'évolution

- Extension à d'autres référentiels (NIST CSF, PCI-DSS, SOC 2).
- Fine-tuning d'un modèle open-source spécialisé.
- Module de benchmarking permettant de comparer plusieurs analyses dans le temps.

- Workflow d'approbation et de signatures électroniques.
- Intégration avec des outils GRC existants via webhooks.
- Déploiement Kubernetes avec mise à l'échelle horizontale.

Apport personnel

Au-delà des compétences techniques, ce projet m'a permis de développer une vision globale de la conduite d'un projet logiciel, depuis la compréhension d'un domaine métier complexe jusqu'à la livraison d'une solution complète.

Bibliographie et webographie

1. ISO/IEC 27001 :2022 – Information security management systems – Requirements.
2. Règlement (UE) 2016/679 du Parlement européen et du Conseil (RGPD).
3. Loi 09-08 relative à la protection des personnes physiques à l'égard du traitement des données à caractère personnel, Royaume du Maroc.
4. Lewis, P. et al., Retrieval-Augmented Generation for Knowledge-Intensive NLP Tasks, NeurIPS, 2020.
5. Documentation FastAPI – <https://fastapi.tiangolo.com>
6. Documentation Mistral AI – <https://docs.mistral.ai>
7. ChromaDB Documentation – <https://docs.trychroma.com>
8. Reimers, N., Gurevych, I., Sentence-BERT, EMNLP 2019.
9. Documentation React – <https://react.dev>
10. Documentation SQLAlchemy 2.0 – <https://docs.sqlalchemy.org>